FIREWALL POLICY
& RULES

Network Security Architecture Programme

Document Reference: SEC-DOC-003 | Version 1.0 | March 2026

CONFIDENTIAL — INTERNAL USE ONLY

Firewalls in Scope: Perimeter FW | Internal FW | DC Firewall | DB Firewall | PCI Firewall | Branch FW

1. Document Information

Document Title	Firewall Policy & Rules
Document Reference	SEC-DOC-003
Version	1.0
Date	March 2026
Classification	**CONFIDENTIAL — INTERNAL USE ONLY**
Status	**APPROVED — All architecture flags resolved. Rules reflect implemented state.**
Firewalls in Scope	Perimeter Firewall (203.0.113.4 / 172.16.10.1 / 172.16.20.1) | Internal Firewall (172.16.21.10) | DC Firewall (172.16.30.1) | DB Firewall | PCI / Payment Firewall | Branch Firewall
Related Documents	SEC-DOC-001 Security Architecture Overview v2.0 | SEC-DOC-002 Network Segmentation & VLAN Design | SEC-DOC-008 Security Controls & Hardening Checklist v2.0

1.1 Purpose

This document defines the firewall policy, rule sets, and change management procedures for all firewalls within the organisation's network security architecture. It provides the authoritative rule base for each firewall, the justification for each rule, and the governance processes that ensure rules remain current, minimal, and auditable.

1.2 Policy Principles

- Default-deny: all traffic is denied unless explicitly permitted by a named rule
- Least privilege: rules permit only the minimum required source, destination, protocol, and port
- Explicit logging: all deny actions and all sensitive permitted flows are logged to the SIEM
- Rule justification: every rule must have a documented business justification and owner
- Review cycle: all rule sets reviewed quarterly; rules unused for 90 days are candidates for removal
- Change control: all rule additions, modifications, or deletions must follow the change management process defined in Section 9
- No any/any rules: wildcard source or destination rules are prohibited without CISO written approval

2. Firewall Inventory

Six firewalls are in scope for this document. Each has a defined role, position in the architecture, and rule set in subsequent sections.

FW ID	Name	IP Address(es)	Position	Interfaces	Role
FW-01	**Perimeter Firewall**	Outside: 203.0.113.4 DMZ: 172.16.10.1 Inside: 172.16.20.1	WAN Edge → DMZ → Internal	Three-legged: Outside, DMZ, Inside	Primary perimeter defence. Enforces separation between Internet, DMZ, and internal network. All internet-facing traffic inspected here.
FW-02	**Internal Firewall**	172.16.21.10	DMZ → Application Services	Two-port: DMZ-facing, App-facing	Second-tier firewall between DMZ and Application Services zone. Enforces HTTPS/API-only inbound from DMZ. Prevents lateral movement from compromised DMZ components.
FW-03	**DC Firewall**	172.16.30.1	Core → Data Centre	Two-port: Core-facing, DC-facing	Entry firewall for the Data Centre zone. Controls all traffic entering from core network to banking servers and databases.
FW-04	**DB Firewall**	172.16.30.x	Core Banking Server → DB Tier	Two-port: App-facing, DB-facing	Dedicated firewall protecting database tier. Ensures only Core Banking Server can reach Core Banking DB and Transaction DB on permitted DB ports.
FW-05	**PCI / Payment Firewall**	172.16.50.x	ATM Gateway → Payment Zone	Two-port: ATM-facing, PCI-facing	Isolates the Payment Processing zone (PCI-DSS scope). Only ATM Gateway and authorised core traffic may enter the payment zone on defined protocols.

FW ID	Name	IP Address(es)	Position	Interfaces	Role
FW-06	**Branch Firewall**	10.12.x.x	Branch LAN → VPN Tunnel	Two-port: LAN-facing, WAN-facing	Branch perimeter firewall. Enforces that all branch-to-HQ traffic transits the IPSec VPN tunnel. Prevents split-tunnelling.

3. Zone Trust Matrix

The following matrix defines whether traffic is permitted between each pair of zones. ALLOW = traffic may flow subject to specific rules. DENY = no traffic permitted in any direction. ONE-WAY = traffic flows only in the direction indicated.

Source \ Dest	Internet	DMZ	App Svcs	Identity Svcs	Core Net	PCI / ATM	SOC	Data Centre	DR Site	Branch
Internet	—	ONE-WAY↓	DENY	DENY	DENY	DENY	DENY	DENY	DENY	DENY
DMZ	ONE-WAY↑	—	ONE-WAY↓	DENY	DENY	DENY	ONE-WAY↓	DENY	DENY	DENY
App Svcs	DENY	ONE-WAY↑	—	ALLOW	DENY	DENY	ONE-WAY↓	ONE-WAY↓	DENY	DENY
Identity Svcs	DENY	DENY	ALLOW	—	ALLOW	DENY	ONE-WAY↓	DENY	DENY	ALLOW
Core Net	DENY	DENY	DENY	ALLOW	—	DENY	ONE-WAY↓	ONE-WAY↓	DENY	ALLOW
PCI / ATM	DENY	DENY	DENY	DENY	DENY	—	ONE-WAY↓	ONE-WAY↓	DENY	DENY
SOC	DENY	ONE-WAY↑	ONE-WAY↑	ONE-WAY↑	ONE-WAY↑	ONE-WAY↑	—	ONE-WAY↑	ONE-WAY↑	ONE-WAY↑
Data Centre	DENY	DENY	ONE-WAY↑	DENY	ONE-WAY↑	ONE-WAY↑	ONE-WAY↓	—	ONE-WAY↓	DENY
DR Site	DENY	DENY	DENY	DENY	DENY	DENY	ONE-WAY↓	ONE-WAY↑	—	DENY
Branch	DENY	DENY	DENY	ALLOW	ALLOW	DENY	ONE-WAY↓	DENY	DENY	—

ONE-WAY↓ = traffic flows FROM source zone TO destination zone only. ONE-WAY↑ = traffic flows FROM destination zone TO source zone only (reverse). ALLOW = bidirectional permitted subject to rules.

4. FW-01 — Perimeter Firewall Rule Set

Three-legged firewall. Interfaces: Outside (203.0.113.4), DMZ (172.16.10.1), Inside (172.16.20.1). Default policy: DENY ALL on all interfaces. Rules are processed top-down; first match wins.

4.1 Inbound — Internet → DMZ

Traffic from untrusted internet destined for DMZ-hosted public services.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-001	Internet	ANY	DMZ	172.16.10.10 (WAF)	TCP	443	**ALLOW**	**YES**	HTTPS inbound to WAF. All internet web traffic enters here first.
PFW-002	Internet	ANY	DMZ	172.16.10.10 (WAF)	TCP	80	**ALLOW**	**YES**	HTTP — WAF redirects to HTTPS. Rule kept for redirect only.
PFW-003	Internet	ANY	DMZ	172.16.10.40 (Public DNS)	UDP	53	**ALLOW**	**YES**	External DNS queries to public authoritative DNS server.
PFW-004	Internet	ANY	DMZ	172.16.10.40 (Public DNS)	TCP	53	**ALLOW**	**YES**	External DNS TCP (zone transfers disabled — authoritative responses only).
PFW-005	Internet	ANY	DMZ	172.16.10.41 (Email GW)	TCP	25	**ALLOW**	**YES**	Inbound SMTP to Email Gateway for mail relay.
PFW-006	Internet	ANY	DMZ	172.16.10.41 (Email GW)	TCP	587	**ALLOW**	**YES**	Inbound authenticated SMTP submission.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-007	Internet	ANY	DMZ	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — all other inbound internet traffic blocked and logged.

4.2 Outbound — DMZ → Internet

Traffic from DMZ components out to the internet (e.g. email delivery, threat intel feeds).

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-010	DMZ	172.16.10.41 (Email GW)	Internet	ANY	TCP	25	**ALLOW**	**YES**	Outbound SMTP from Email Gateway for mail delivery.
PFW-011	DMZ	172.16.10.41 (Email GW)	Internet	ANY	TCP	465,587	**ALLOW**	**YES**	Outbound SMTPS for authenticated relay.
PFW-012	DMZ	172.16.10.10 (WAF)	Internet	ANY	TCP	443	**ALLOW**	**YES**	WAF outbound HTTPS for threat intelligence feed updates.
PFW-013	DMZ	ANY	Internet	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — all other DMZ-to-internet traffic blocked and logged.

4.3 DMZ → Internal (Inside Interface)

Traffic from DMZ components toward the internal network. Strictly controlled — WAF and Reverse Proxy are the only permitted sources.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-020	DMZ	172.16.10.11 (Rev Proxy)	Internal	172.16.21.10 (Internal FW)	TCP	443	**ALLOW**	**YES**	Reverse Proxy forwards HTTPS traffic to Internal Firewall for App Services.
PFW-021	DMZ	172.16.10.30 (API GW)	Internal	172.16.21.10 (Internal FW)	TCP	443,8443	**ALLOW**	**YES**	API Gateway forwards API calls to Internal Firewall.
PFW-022	DMZ	ANY	Internal	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — no other DMZ component may initiate connections to internal network.

4.4 Internal → DMZ

Traffic from internal zones back to DMZ (e.g. management access to DMZ components).

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-030	Internal	10.10.30.0/24 (IT/Admin VLAN)	DMZ	172.16.10.10 (WAF)	TCP	443,8443	**ALLOW**	**YES**	IT Admin VLAN may access WAF management console over HTTPS.
PFW-031	Internal	10.10.30.0/24 (IT/Admin VLAN)	DMZ	172.16.10.11 (Rev Proxy)	TCP	443	**ALLOW**	**YES**	IT Admin may access Reverse Proxy management.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-032	Internal	10.10.30.0/24 (IT/Admin VLAN)	DMZ	172.16.10.41 (Email GW)	TCP	443	**ALLOW**	**YES**	IT Admin may access Email Gateway management console.
PFW-033	Internal	10.10.50.0/24 (OOB Mgmt)	DMZ	ANY	TCP	22	**ALLOW**	**YES**	OOB management VLAN SSH access to DMZ devices for emergency management.
PFW-034	Internal	ANY	DMZ	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — all other internal-to-DMZ traffic blocked.

4.5 Perimeter Firewall — Management Rules

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-040	OOB Mgmt	10.10.50.0/24	Perimeter FW	203.0.113.4	TCP	22	**ALLOW**	**YES**	SSH management from OOB VLAN only. Telnet prohibited.
PFW-041	OOB Mgmt	10.10.50.0/24	Perimeter FW	203.0.113.4	TCP	443	**ALLOW**	**YES**	HTTPS management GUI from OOB VLAN only.
PFW-042	ANY	ANY	Perimeter FW	203.0.113.4	TCP	22,443	**DENY**	**YES**	Block management access from any non-OOB source. Logged as HIGH alert.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PFW-043	Perimeter FW	203.0.113.4	SOC	172.16.66.20	UDP	514	**ALLOW**	**NO**	Syslog from Perimeter FW to Log Collector.

5. FW-02 — Internal Firewall Rule Set

Position: between DMZ and Application Services zone. IP: 172.16.21.10. Default policy: DENY ALL. Only HTTPS and defined API ports permitted inbound from DMZ.

5.1 DMZ → Application Services

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
IFW-001	DMZ	172.16.10.11 (Rev Proxy)	App Svcs	172.16.20.10 (Banking App)	TCP	443	**ALLOW**	**YES**	Banking application HTTPS traffic from Reverse Proxy.
IFW-002	DMZ	172.16.10.11 (Rev Proxy)	App Svcs	172.16.20.11 (Mobile Backend)	TCP	443	**ALLOW**	**YES**	Mobile backend HTTPS traffic from Reverse Proxy.
IFW-003	DMZ	172.16.10.30 (API GW)	App Svcs	172.16.20.10 (Banking App)	TCP	8443	**ALLOW**	**YES**	Banking API calls from API Gateway.
IFW-004	DMZ	172.16.10.30 (API GW)	App Svcs	172.16.20.11 (Mobile Backend)	TCP	8443	**ALLOW**	**YES**	Mobile API calls from API Gateway.
IFW-005	DMZ	ANY	App Svcs	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — no other DMZ traffic may reach Application Services.

5.2 Application Services → Identity Services

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
IFW-010	App Svcs	172.16.20.10 (Banking App)	Identity Svcs	172.16.60.10 (AD)	TCP	636	**ALLOW**	**YES**	LDAPS — app authenticates users against Active Directory.
IFW-011	App Svcs	172.16.20.11 (Mobile Backend)	Identity Svcs	172.16.60.10 (AD)	TCP	636	**ALLOW**	**YES**	LDAPS — mobile backend authenticates users against AD.
IFW-012	App Svcs	172.16.20.10 (Banking App)	Identity Svcs	172.16.60.12 (RADIUS)	UDP	1812	**ALLOW**	**YES**	RADIUS authentication for banking app sessions.
IFW-013	App Svcs	172.16.20.12 (IAM)	Identity Svcs	172.16.60.10 (AD)	TCP	636	**ALLOW**	**YES**	IAM Server LDAPS queries to AD.
IFW-014	App Svcs	172.16.20.10/11	App Svcs	172.16.20.13 (MFA)	TCP	443	**ALLOW**	**YES**	Apps call MFA Server for token validation.
IFW-015	App Svcs	172.16.20.13 (MFA)	App Svcs	172.16.20.12 (IAM)	TCP	443	**ALLOW**	**YES**	MFA Server calls IAM Server for policy lookup.
IFW-016	App Svcs	ANY	Identity Svcs	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — no other app traffic to Identity zone.

5.3 Application Services → Data Centre

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
IFW-020	App Svcs	172.16.20.10 (Banking App)	DC	172.16.30.1 (DC FW)	TCP	443	**ALLOW**	**YES**	Banking App to DC Firewall — HTTPS to Core

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
									Banking Server.
IFW-021	App Svcs	172.16.20.11 (Mobile Backend)	DC	172.16.30.1 (DC FW)	TCP	443	**ALLOW**	**YES**	Mobile Backend to DC Firewall — HTTPS.
IFW-022	App Svcs	ANY	DC	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny.

5.4 Application Services → SOC (Log Forwarding)

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
IFW-030	App Svcs	172.16.20.10 (Banking App)	SOC	172.16.66.20 (Log Collector)	TCP	1514	**ALLOW**	**NO**	Wazuh agent log forwarding from Banking App.
IFW-031	App Svcs	172.16.20.11 (Mobile Backend)	SOC	172.16.66.20	TCP	1514	**ALLOW**	**NO**	Wazuh agent log forwarding from Mobile Backend.
IFW-032	App Svcs	172.16.20.12 (IAM)	SOC	172.16.66.20	TCP	1514	**ALLOW**	**NO**	Wazuh agent log forwarding from IAM Server.
IFW-033	App Svcs	172.16.20.13 (MFA)	SOC	172.16.66.20	TCP	1514	**ALLOW**	**NO**	Wazuh agent log forwarding from MFA Server.
IFW-034	Internal FW	172.16.21.10	SOC	172.16.66.20	UDP	514	**ALLOW**	**NO**	Syslog from Internal Firewall to Log Collector.

5.5 Internal Firewall — Management

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
IFW-040	OOB Mgmt	10.10.50.0/24	Internal FW	172.16.21.10	TCP	22,443	**ALLOW**	**YES**	SSH and HTTPS management from OOB VLAN only.
IFW-041	ANY	ANY	Internal FW	172.16.21.10	TCP	22,443	**DENY**	**YES**	Block management from any non-OOB source.

6. FW-03 — DC Firewall Rule Set

Position: entry firewall for Data Centre zone. IP: 172.16.30.1. Controls all access to Core Banking Server, DB tier, Storage, and Backup from the core network.

6.1 App Services / Core → Data Centre

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
DCF-001	App Svcs	172.16.20.10 (Banking App)	DC	172.16.30.x (Core Banking Svr)	TCP	443	**ALLOW**	**YES**	Banking App HTTPS to Core Banking Server.
DCF-002	App Svcs	172.16.20.11 (Mobile Backend)	DC	172.16.30.x (Core Banking Svr)	TCP	443	**ALLOW**	**YES**	Mobile Backend HTTPS to Core Banking Server.
DCF-003	Core Net	10.10.30.0/24 (IT/Admin)	DC	172.16.30.1 (DC FW)	TCP	443	**ALLOW**	**YES**	IT Admin HTTPS management access to DC Firewall.
DCF-004	OOB Mgmt	10.10.50.0/24	DC	172.16.30.1 (DC FW)	TCP	22,443	**ALLOW**	**YES**	OOB SSH and HTTPS management to DC Firewall and DC servers.
DCF-005	PCI Zone	172.16.50.30 (Txn Server)	DC	172.16.30.20 (Core Banking DB)	TCP	1521	**ALLOW**	**YES**	Transaction Server writes to Core Banking DB (Oracle). PCI-controlled path.
DCF-006	ANY	ANY	DC	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — all other access to Data Centre blocked.

6.2 Data Centre → DR Site (Replication)

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
DCF-010	DC	172.16.30.20 (Core Banking DB)	DR Site	DR Replication Node	TCP	5432,1521	**ALLOW**	**YES**	Database replication — PostgreSQL / Oracle to DR Database.
DCF-011	DC	172.16.30.40 (Backup)	DR Site	DR Backup Node	TCP	9000,443	**ALLOW**	**YES**	Backup replication to DR Backup node.
DCF-012	DC	ANY	DR Site	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — only replication traffic permitted to DR.

6.3 Data Centre → SOC

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
DCF-020	DC	172.16.30.x (Core Banking Svr)	SOC	172.16.66.20 (Log Collector)	TCP	1514	**ALLOW**	**NO**	Wazuh agent from Core Banking Server.
DCF-021	DC	172.16.30.20 (Core Banking DB)	SOC	172.16.66.20	TCP	1514	**ALLOW**	**NO**	Wazuh agent from Core Banking DB.
DCF-022	DC	172.16.30.21 (Transaction DB)	SOC	172.16.66.20	TCP	1514	**ALLOW**	**NO**	Wazuh agent from Transaction DB.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
DCF-023	DC	172.16.30.1 (DC FW)	SOC	172.16.66.20	UDP	514	**ALLOW**	**NO**	Syslog from DC Firewall.

7. FW-04 — DB Firewall Rule Set

Position: between Core Banking Server and database tier. Protects Core Banking DB (172.16.30.20) and Transaction DB (172.16.30.21). No direct access to databases except via this firewall from Core Banking Server.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
DBF-001	DC	172.16.30.x (Core Banking Svr)	DB Tier	172.16.30.20 (Core Banking DB)	TCP	1521	**ALLOW**	**YES**	Core Banking Server → Core Banking DB (Oracle). Only permitted source.
DBF-002	DC	172.16.30.x (Core Banking Svr)	DB Tier	172.16.30.21 (Transaction DB)	TCP	1521	**ALLOW**	**YES**	Core Banking Server → Transaction DB (Oracle).
DBF-003	DC	172.16.30.x (Core Banking Svr)	DB Tier	172.16.30.20 (Core Banking DB)	TCP	5432	**ALLOW**	**YES**	Core Banking Server → Core Banking DB (PostgreSQL fallback).
DBF-004	DB Tier	172.16.30.20/21	DC	172.16.30.x (Core Banking Svr)	TCP	ANY	**ALLOW**	**YES**	Database response traffic back to Core Banking Server.
DBF-005	DB Tier	172.16.30.20 (Core Banking DB)	DC	172.16.30.40 (Backup)	TCP	9000	**ALLOW**	**YES**	DB replication to Backup node.
DBF-006	DB Tier	172.16.30.21 (Transaction DB)	DC	172.16.30.40 (Backup)	TCP	9000	**ALLOW**	**YES**	Transaction DB replication to Backup node.
DBF-007	OOB Mgmt	10.10.50.0/24	DB Tier	172.16.30.20/21	TCP	22	**ALLOW**	**YES**	Emergency SSH DBA access from

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
									OOB VLAN only.
DBF-008	ANY	ANY	DB Tier	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — all other access to DB tier blocked and alerted.

CRITICAL: Any non-compliant connection attempt to the DB tier (rule DBF-008) triggers a HIGH severity SIEM alert requiring SOC acknowledgement within 15 minutes.

8. FW-05 — PCI / Payment Firewall Rule Set

Position: between ATM Network / Core and Payment Processing zone (172.16.50.x). PCI-DSS v4.0 scope. All rules subject to QSA review. Strict default-deny with minimal permitted flows.

8.1 ATM Zone → Payment Processing

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PCF-001	ATM Net	ATM Gateway	PCI Zone	172.16.50.10 (Payment GW)	TCP	443	**ALLOW**	**YES**	ATM financial transactions to Payment Gateway over HTTPS/TLS 1.3.
PCF-002	ATM Net	ATM Gateway	PCI Zone	172.16.50.10 (Payment GW)	TCP	8443	**ALLOW**	**YES**	ATM transaction API calls to Payment Gateway.
PCF-003	ATM Net	ANY	PCI Zone	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — ATM zone has no other access to Payment Processing.

8.2 Payment Processing Internal Flow

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PCF-010	PCI Zone	172.16.50.10 (Payment GW)	PCI Zone	172.16.50.20 (Card Processing)	TCP	443	**ALLOW**	**YES**	Payment Gateway to Card Processing — internal PCI flow.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PCF-011	PCI Zone	172.16.50.20 (Card Processing)	PCI Zone	172.16.50.30 (Txn Server)	TCP	443	**ALLOW**	**YES**	Card Processing to Transaction Server — authorisation.
PCF-012	PCI Zone	172.16.50.30 (Txn Server)	DC	172.16.30.20 (Core Banking DB)	TCP	1521	**ALLOW**	**YES**	Transaction Server to Core Banking DB — settlement writes.

8.3 Payment Zone — Management and Logging

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
PCF-020	OOB Mgmt	10.10.50.0/24	PCI Zone	172.16.50.10/20/30	TCP	22	**ALLOW**	**YES**	Emergency SSH from OOB VLAN. Dual-approval required for PCI access.
PCF-021	PCI Zone	172.16.50.10/20/30	SOC	172.16.66.20 (Log Collector)	TCP	1514	**ALLOW**	**NO**	Wazuh agents on all PCI components log to SOC.
PCF-022	PCI Zone	172.16.50.x (PCI FW)	SOC	172.16.66.20	UDP	514	**ALLOW**	**NO**	Syslog from PCI Firewall.
PCF-023	ANY	ANY	PCI Zone	ANY	ANY	ANY	**DENY**	**YES**	Implicit deny — all other access to PCI zone blocked. CRITICAL alert generated.

9. FW-06 — Branch Firewall Rule Set

Position: branch office LAN perimeter. All traffic to HQ must transit IPSec VPN tunnel. Split-tunnelling prohibited. Branch VLAN: 10.12.0.0/24.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port(s)	Action	Log	Notes
BRF-001	Branch	10.12.0.0/24	VPN Tunnel	10.0.0.1/2 (Core Routers)	ESP	—	**ALLOW**	**YES**	IPSec ESP — encrypted VPN tunnel traffic to Core Routers.
BRF-002	Branch	10.12.0.0/24	VPN Tunnel	10.0.0.1/2	UDP	500,4500	**ALLOW**	**YES**	IKEv2 key exchange for IPSec VPN establishment.
BRF-003	Branch	10.12.0.0/24	Identity Svcs	172.16.60.10 (AD)	TCP	636	**ALLOW**	**YES**	Branch users LDAPS authentication to AD (via VPN).
BRF-004	Branch	10.12.0.0/24	Identity Svcs	172.16.60.12 (RADIUS)	UDP	1812	**ALLOW**	**YES**	Branch RADIUS authentication (via VPN).
BRF-005	Branch	10.12.0.0/24	App Svcs	172.16.20.10 (Banking App)	TCP	443	**ALLOW**	**YES**	Branch staff access to Banking App (via VPN).
BRF-006	Branch	10.12.0.0/24	SOC	172.16.66.20 (Log Collector)	UDP	514	**ALLOW**	**NO**	Branch devices syslog to SOC Log Collector.
BRF-007	Branch	10.12.0.0/24	Internet	ANY	TCP	443,80	**DENY**	**YES**	Split-tunnel PROHIBITED. Internet traffic must route via HQ. Block direct internet.
BRF-008	Internet	ANY	Branch	ANY	ANY	ANY	**DENY**	**YES**	No inbound internet traffic to branch.
BRF-009	OOB Mgmt	10.10.50.0/24	Branch FW	10.12.x.x	TCP	22,443	**ALLOW**	**YES**	Management of Branch Firewall from OOB VLAN at HQ.

10. Global Rules — Applied to All Firewalls

The following rules apply to every firewall in scope. They are implemented as the first and last rules in every rule set.

Rule ID	Src Zone	Source	Dst Zone	Destination	Proto	Port	Action	Log	Notes
GLB-001	ANY	ANY	ANY	Firewall Mgmt Interface	TCP	22,443	**DENY**	**YES**	Block management interface access from non-OOB sources — all FWs.
GLB-002	ANY	ANY	ANY	ANY	TCP/UDP	0	**DENY**	**YES**	Block any traffic on port 0.
GLB-003	ANY	RFC1918	Internet	ANY	ANY	ANY	**DENY**	**YES**	Block private address ranges from appearing on internet interfaces (anti-spoofing).
GLB-004	ANY	ANY	ANY	ANY	ANY	ANY	**DENY**	**YES**	Explicit final deny-all. Logged as LOW. All other traffic blocked.

11. Rule Review & Change Management

11.1 Review Cycle

- Quarterly full rule-set review for all firewalls by Network Security team
- Rules with no traffic in the previous 90 days flagged for removal review
- Annual review by QSA for all PCI-in-scope firewalls (FW-04, FW-05)
- Any new firewall or major architecture change triggers an immediate rule review for affected firewalls

11.2 Change Management Process

All firewall rule changes must follow this process without exception:

Step	Action	Owner	Requirement
1	**Raise Change Request**	Requestor	Document: rule purpose, source, destination, protocol, port, business justification, and rule owner
2	**Peer Review**	Senior Network Engineer	Second engineer must review and approve all rule changes before implementation
3	**Security Review**	Security Architect	Any rule permitting new protocols, ports, or cross-zone flows requires Security Architect sign-off
4	**PCI Review (if applicable)**	Security Architect + CISO	Rules affecting FW-04 or FW-05 require CISO written approval and are logged for QSA review
5	**Implementation**	Network Engineer	Change implemented in agreed maintenance window. Dual-person rule for PCI firewall changes
6	**Validation**	Network Engineer	Confirm rule behaves as expected. Test connectivity where applicable. Confirm logging active
7	**Documentation Update**	Network Engineer	Update this document with new rule. Update SIEM alert logic if required
8	**Post-Change Review**	Change Manager	72-hour post-change review period. Rule rolled back if unexpected traffic observed

11.3 Emergency Change Process

Emergency firewall changes (required outside of maintenance windows to respond to an active incident) must follow the following expedited process:

- Verbal approval from Security Architect or CISO before implementation
- Change implemented by two engineers (dual-control)
- Change Request raised within 2 hours of implementation, even if verbal approval was given
- Emergency changes reviewed in next business day for confirmation or rollback
- Emergency changes to PCI firewalls (FW-04, FW-05) are logged separately for QSA report

12. Logging & Alerting Policy

All firewalls forward logs to the SOC Log Collector (172.16.66.20) via syslog UDP/514. The following alert thresholds apply to firewall-generated events in the Wazuh SIEM:

Event	Firewall	Severity	SOC Response SLA
Connection to management interface from non-OOB source	All	CRITICAL	Immediate alert. SOC response within 5 minutes. Incident raised automatically.
Any connection attempt hitting DBF-008 (implicit deny on DB tier)	FW-04	HIGH	Alert within 15 minutes. SOC investigates. Potential lateral movement indicator.
Any connection attempt hitting PCF-023 (implicit deny on PCI zone)	FW-05	HIGH	Alert within 15 minutes. Possible PCI breach indicator. CISO notified.
More than 100 deny hits/minute from same source IP on any interface	All	HIGH	Possible port scan or DDoS. Automated block rule triggered. SOC review.
Firewall configuration change detected (outside change window)	All	HIGH	Alert immediately. Possible unauthorised change. SOC + Change Manager notified.
Split-tunnel block rule BRF-007 triggered from branch	FW-06	MEDIUM	Log only. Review weekly. Repeated hits escalate to HIGH.
Any rule not logged triggering deny	All	LOW	Batch report to SOC daily.
Normal permitted traffic deny (standard end-of-ruleset)	All	LOW	Batch report only.

13. Rule Summary

Firewall	Description	ALLOW Rules	DENY Rules	LOG Rules	Total Rules	Notes
FW-01	Perimeter Firewall	**11**	**4**	All	**15**	Three-legged. Covers 5 sub-sections.
FW-02	Internal Firewall	**14**	**4**	All	**18**	Covers App→Identity, App→DC, log forwarding.
FW-03	DC Firewall	**8**	**3**	All	**11**	Covers inbound, DR replication, log forwarding.
FW-04	DB Firewall	**8**	**1**	All	**9**	Strict. Any deny triggers HIGH SIEM alert.
FW-05	PCI / Payment FW	**8**	**3**	All	**11**	PCI-DSS scope. QSA reviewed annually.
FW-06	Branch Firewall	**9**	**2**	All	**11**	IPSec VPN enforced. No split-tunnelling.
Global	All Firewalls	**0**	**4**	All	**4**	Applied to every firewall as first/last rules.

Appendix A: IP Address Reference

Quick reference for all IP addresses referenced in rule sets.

Name	IP Address	Zone	Used in Rules
Perimeter Firewall (Outside)	203.0.113.4	Perimeter	PFW-040–043
Perimeter Firewall (DMZ IF)	172.16.10.1	DMZ	PFW-001–034
Perimeter Firewall (Inside IF)	172.16.20.1	Internal	PFW-020–034
WAF	172.16.10.10	DMZ	PFW-001,002,012,030
Reverse Proxy	172.16.10.11	DMZ	PFW-020, IFW-001,002
Load Balancer	172.16.10.12	DMZ	—
Public DNS	172.16.10.40	DMZ	PFW-003,004
Email Gateway	172.16.10.41	DMZ	PFW-005,006,010,011,032
Web Server	172.16.10.20	DMZ Web Servers	—
API Gateway	172.16.10.30	DMZ Web Servers	PFW-021, IFW-003,004
Internal Firewall	172.16.21.10	Internal FW Zone	IFW-001–041
Banking App	172.16.20.10	Application Services	IFW-010,020, DCF-001
Mobile Backend	172.16.20.11	Application Services	IFW-011,021, DCF-002
IAM Server	172.16.20.12	Application Services	IFW-013,032
MFA Server	172.16.20.13	Application Services	IFW-014,015,033
Active Directory	172.16.60.10	Identity Services	IFW-010,011,013, BRF-003
DNS (Internal)	172.16.60.11	Identity Services	—
RADIUS	172.16.60.12	Identity Services	IFW-012, BRF-004
DHCP	172.16.60.13	Identity Services	—

Name	IP Address	Zone	Used in Rules
DC Firewall	172.16.30.1	Data Centre	DCF-001–023
Core Banking Server	172.16.30.x	Data Centre	DCF-001,002, DBF-001–004
Core Banking DB	172.16.30.20	Data Centre	DBF-001,003,005, PCF-012
Transaction DB	172.16.30.21	Data Centre	DBF-002,004,006
Backup	172.16.30.40	Data Centre	DCF-011, DBF-005,006
Payment Gateway	172.16.50.10	Payment / PCI	PCF-001,002,010
Card Processing	172.16.50.20	Payment / PCI	PCF-010,011
Transaction Server	172.16.50.30	Payment / PCI	PCF-011,012, DCF-005
Log Collector (SIEM)	172.16.66.20	SOC	IFW-030–034, DCF-020–023, PCF-021,022
Wazuh SIEM	172.16.66.10	SOC	—
SOC Dashboard	172.16.66.30	SOC	—
OOB Management VLAN	10.10.50.0/24	VLAN 50	PFW-040,041, IFW-040, DCF-004, DBF-007, PCF-020, BRF-009
Core Router 1	10.0.0.1	Core Network	BRF-001,002
Core Router 2	10.0.0.2	Core Network	BRF-001,002
Branch LAN	10.12.0.0/24	Branch Office	BRF-001–009

Appendix B: Revision History

Version	Date	Author	Description
1.0	March 2026	Security Architecture Team	Initial release. Rule sets defined for all 6 firewalls based on confirmed architecture (SEC-DOC-001 v2.0). All zones verified from architecture screenshots. Includes perimeter, internal, DC, DB, PCI, and branch firewalls. Global rules and logging policy defined.

Appendix C: Related Documents

Ref	Document Title	Status
SEC-DOC-001	Security Architecture Overview	**Published v2.0**
SEC-DOC-002	Network Segmentation & VLAN Design	Pending
SEC-DOC-003	Firewall Policy & Rules (this document)	**Published v1.0**
SEC-DOC-004	Log Collection & SIEM Architecture	Pending
SEC-DOC-005	Identity & Access Management (IAM)	**Published v1.0**
SEC-DOC-006	Data Flow Diagram & Traffic Matrix	Pending
SEC-DOC-007	Disaster Recovery & Backup Plan	Pending
SEC-DOC-008	Security Controls & Hardening Checklist	**Published v2.0**